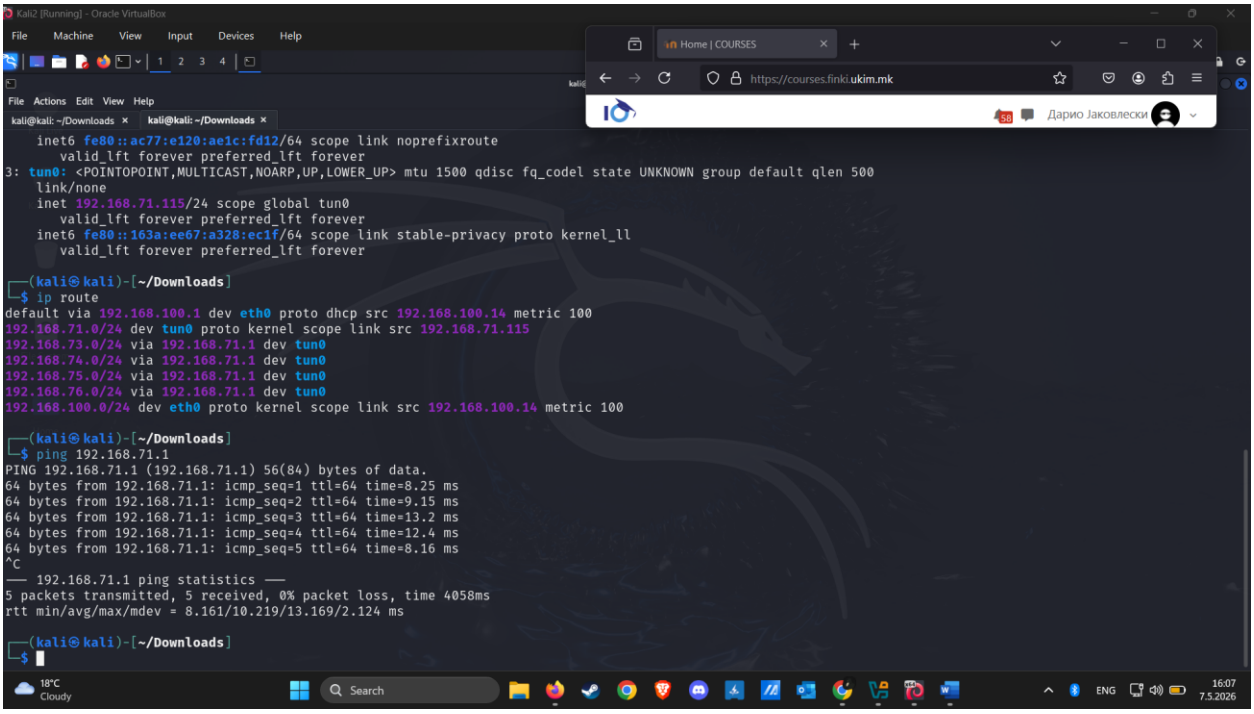
Лабораториска вежба 6 – Pivoting	*Име и презиме* *Дарио Јаковлески*	*Индекс* *222015*

Текстуалните одговори давајте ги со црвена боја.

1. Дел 1

Прашање 1: Дали pingot беше успешен? Поставете слика. Дополнително, погледајте ја рутирачката табела на Kali сега. Која наредба ја користевте и што забележувате? Поставете слика и од рутирачката табела.

Одговор 1:

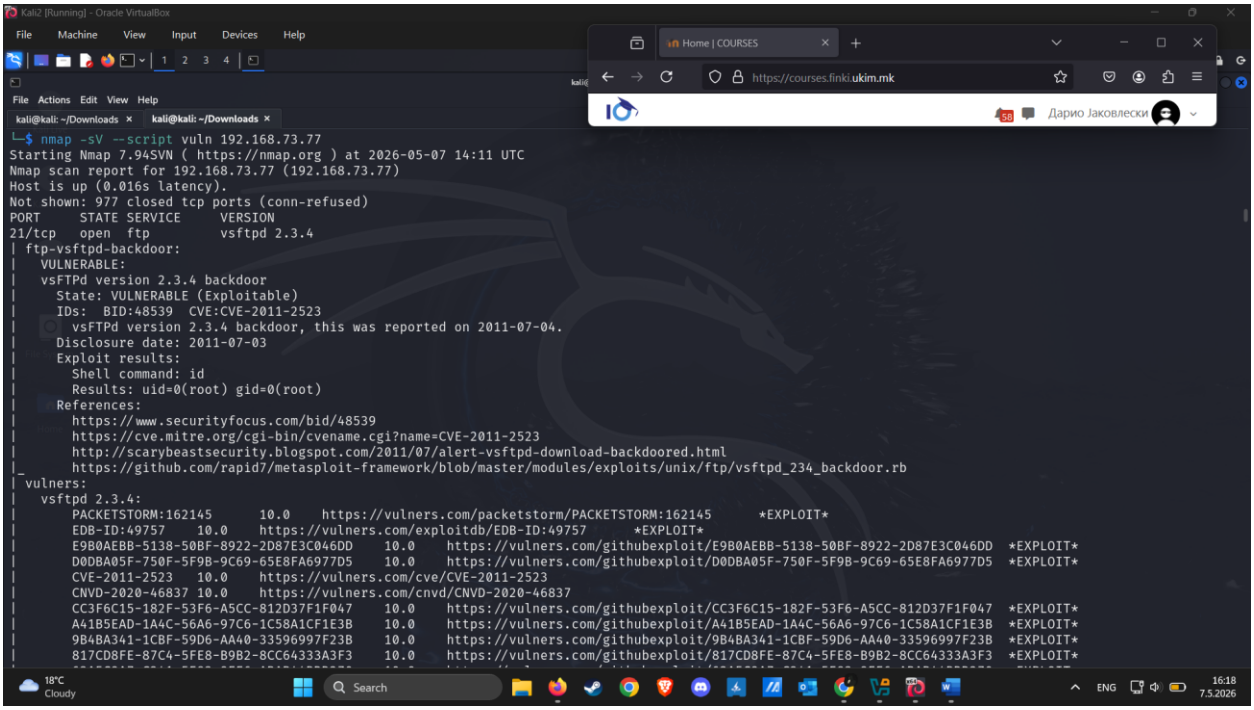


Ping-от беше успешен — добив одговори од 192.168.71.1 без загуба на пакети. За прегледување на рутирачката табела ја користев наредбата ip route. По поврзувањето на VPN, во рутирачката табела се појавија нови записи поврзани со tun0 интерфејсот. Конкретно, додадена е рута за мрежата на ФИНКИ инфраструктурата (пр. 192.168.71.0/24) која минува преку tun0, кој е виртуелниот мрежен интерфејс создаден од OpenVPN. Ова значи дека сообраќајот кон таа мрежа сега се насочува преку VPN тунелот наместо преку стандардниот gateway.

2. Дел 2

Прашање 2: Кои ранливости ги откривте на машината и која алатка ја користевте? Образложете.

Одговор 2:



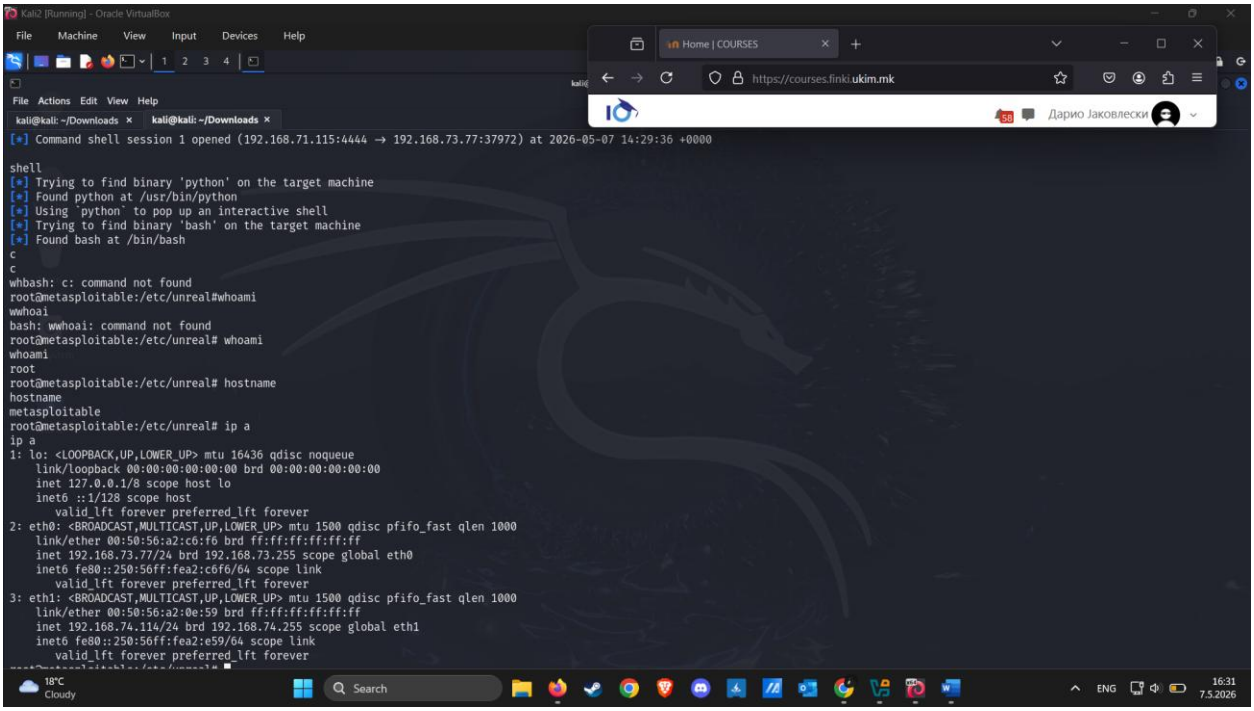
За скенирање на ранливости ја користев алатката nmap со параметрите -sV (детекција на верзии на сервиси) и --script vuln (автоматско скенирање за познати ранливости.

Машината има многу ранливости, но како позначајни се:

ftp-vsftpd-backdoor, openbsd:openssh:4.7p1:,isc:bind:9.4.2, apache:http_server:2.2.8, UnrealIRCd и тн.

Прашање 3: Дали успеавте да ја пробиете машината и да отворите сесија? Поставете слика од извршувањето на наредбите whoami, hostname, и ip a.

Одговор 3:



Успеав да ја пробијам машината и да отворам командна сесија.

Прашање 4: По извршувањето на ip a наредбата, колку мрежни интерфејси можевте да изброите? Колку од нив се ethernet интерфејси?

Одговор 4:

Од излезот на ip a наредбата гледам 3 мрежни интерфејси: lo (loopback), eth0 и eth1. Од нив, 2 се Ethernet интерфејси — eth0 и eth1. Присуството на два ethernet интерфејси укажува дека оваа машина е поврзана на две различни мрежи истовремено, што е клучно за pivoting.

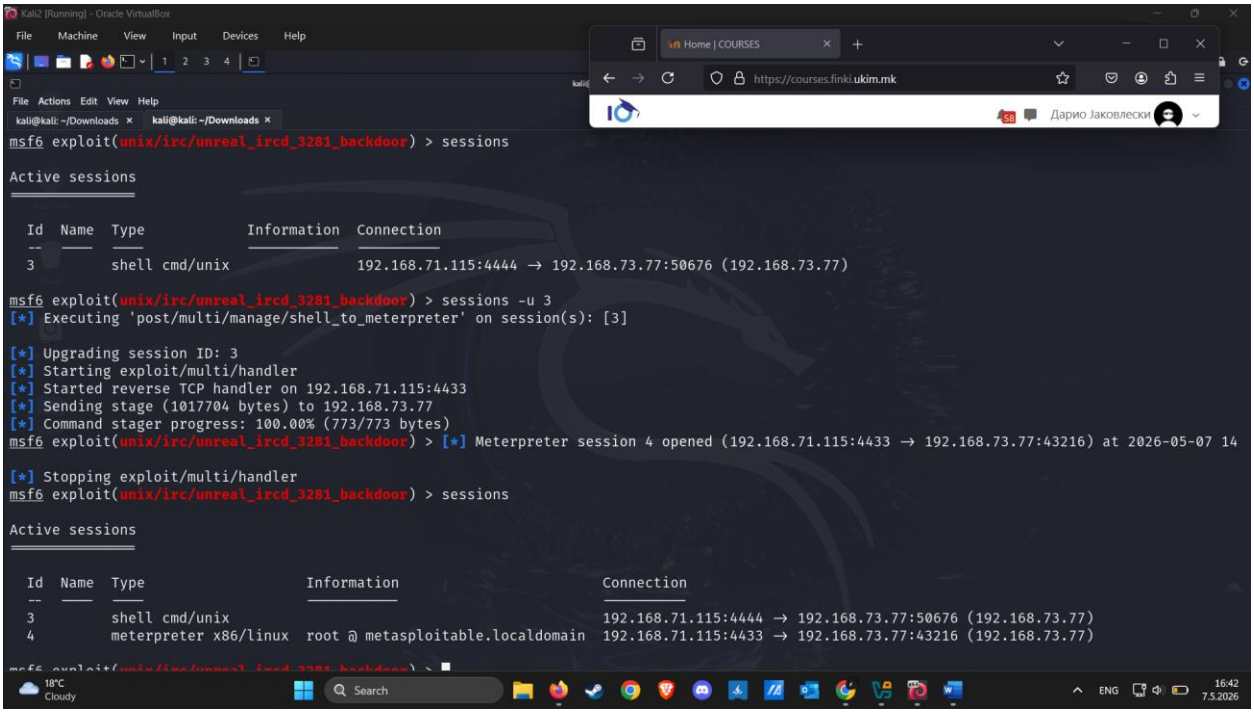
Прашање 5: Која е IP адресата на вториот ethernet интерфејс?

Одговор 5:

192.168.74.114/24

Прашање 6: Дали надградбата на сесијата беше успешна? Прегледајте ги моментално активните сесии со извршување на наредбата sessions и поставете слика.

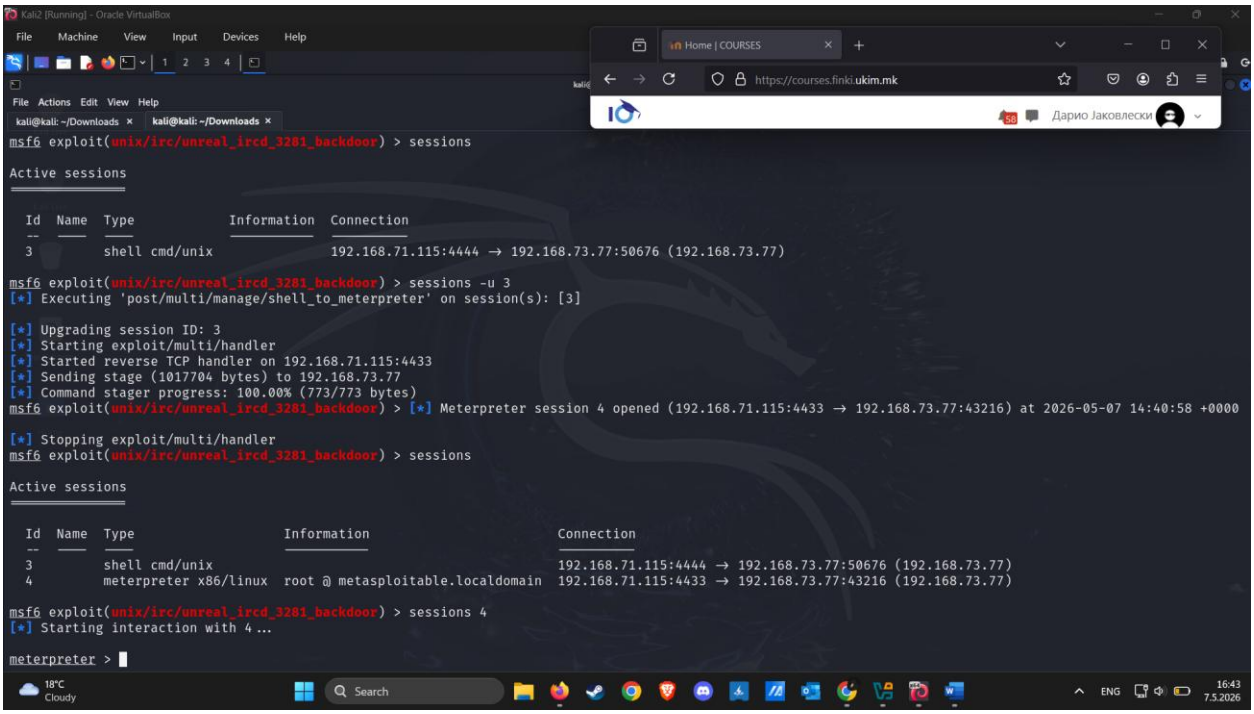
Одговор 6:



Надградбата на сесијата беше успешна. По извршување на sessions -u 3, Metasploit автоматски го зеде постоечкиот shell и го надгради во Meterpreter сесија.

Прашање 7: Активирајте ја Meterpreter сесијата со извршување на sessions $METERPRETER_ID и поставете слика од prompt-от.

Одговор 7:



3. Дел 3

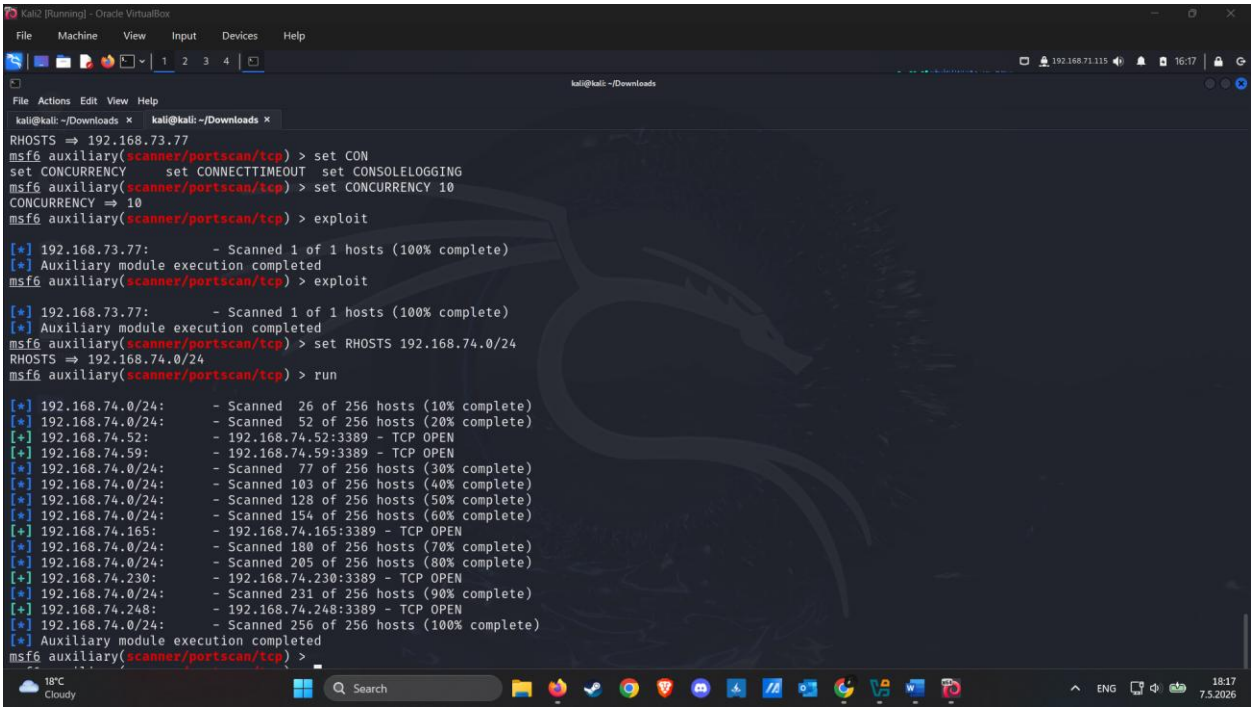
Прашање 8: Како би изгледала наредбата за поставување на рута до мрежата достапна преку вториот интерфејс? Пазете на разликата помеѓу host адреса и адреса на мрежа. Наведување на адреса на хост во шаблонот носи -10 поени.

Одговор 8:

Наредбата би изгледала вака: run autoroute -s 192.168.74.0 255.255.255.0.

Прашање 9: Дали откривте хостови со отворена порта 3389? Кои се тие? Наведете ги адресите на хостовите кои ги откривте и поставете слика од процесот на скенирање.

Одговор 9:



Да најдов 5 windows hosts.

[+] 192.168.74.52: - 192.168.74.52:3389 - TCP OPEN

[+] 192.168.74.59: - 192.168.74.59:3389 - TCP OPEN

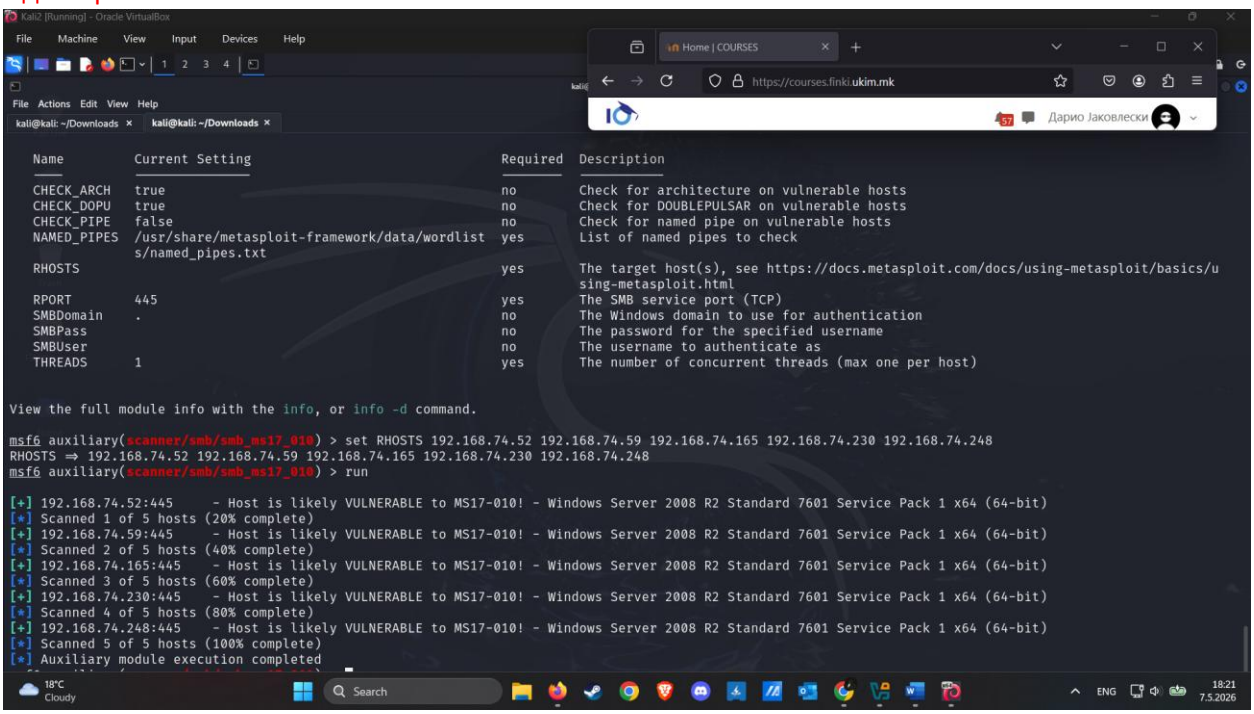
[+] 192.168.74.165: - 192.168.74.165:3389 - TCP OPEN

[+] 192.168.74.230: - 192.168.74.230:3389 - TCP OPEN

[+] 192.168.74.248: - 192.168.74.248:3389 - TCP OPEN

Прашање 10: Дали откриениот хост е ранлив на Eternalblue?

Одговор 10:



Да сите 5 се ранливи.

Прашање 11: За кој exploit за експлоатација се одлучивте? Зошто?

Одговор 11:

Се одлучив за EternalBlue (MS17-010) exploit, бидејќи претходното скенирање потврди дека машината е ранливаПредноста на овој exploit е директното добивање на Meterpreter shell со SYSTEM привилегии, без потреба од дополнителна надградба на привилегии.

Прашање 12: Дали процесот на експлоатација беше успешен? Образложете.

Одговор 12:

Не успеав да се поврзам на Wndows машината иако пробав на побеќе начини користеќи различни exploits и payloads кои пример EternalBLue кое даваше log дека exploit-от е успешен но правеше проблем со воспоставувањето на сесијата со машината. Иако се осигурав дека имам додатено autoroute кај првата жтрва, пробав и reverse_tcp и bind_tcp, пробав и со proxy chains, не успеваше...

Прашање 13: Извршете ја systeminfo наредбата преку shell отворен од Meterpreter. Поставете слика од излезот.

Одговор 13 :

/